# Security Hardening Assessment Program — Charter & 16-Week Roadmap

Oct 23, 2026 · @Manas · Draft v0.6

## Purpose and objectives

In 16 weeks (start date to be confirmed), the program assesses the security of the OS, container, cloud, network, data, application, identity, detection and blockchain layers. It delivers prioritized, actionable hardening recommendations. It also cross-checks NIST CSF 2.0, NIST SP 800-53, ISO 27001, SOC 2, CIS, BSSC, PCI DSS and the regulatory overlays against each other, so that one assessment produces evidence for all of them. Work is ordered by threat: the attack paths to the crown jewels are assessed first and in full depth. **The program assesses and recommends; it does not implement.** The owning platform, product and security operations teams do the implementation. The program defines what to fix, why, to which standard, in what order, and how each fix will be verified.

**Objectives**

1. **Set governance, scope and threat focus.** By week 2, agree:
   - the governance model and gate criteria;
   - a reconciled asset inventory;
   - the *current-state* architecture and the crown jewels;
   - 6–8 named attack scenarios against those crown jewels;
   - rules of engagement and evidence-handling rules.
2. **Cross-check the industry standards in full.** Every requirement of NIST CSF 2.0, SP 800-53 Rev 5, ISO/IEC 27001:2022, SOC 2, CIS (Controls v8.1 and Benchmarks), BSSC, PCI DSS (if in scope) and the regulatory overlays gets a recorded relationship decision. The cross-check shows where standards agree, where one is stricter, where they conflict, and what no test in this program reaches. It is built in three versions:
   - v1 (week 2): published mappings only, labeled *candidate*.
   - v2 (week 7): links for every control tested in Tier 1, reviewed.
   - v3 (week 13): the full catalogue.
3. **Assess the current state**, crown-jewel attack paths first, backed by evidence. Each test runs once and counts for every standard it validly maps to.

4. **Validate findings.** Each finding is rated by its attack-path proximity to a crown jewel, traced to every applicable standard, and fact-checked with the system owner.
5. **Recommend target baselines and hardening actions.** Each is specific and testable, with effort, owner team, priority and a verification method. The target-state architecture is delivered with them in week 14.
6. **Sequence the remediation roadmap** (Now / Next / Later) and design the remediation governance that takes over at handover.
7. **Hand over a unified findings and control register** to GRC as its long-term owner, ready for re-assessment and audits.

### Deliverables

| Deliverable | Workstream | Due |
|---|---|---|
| Charter, governance model, gate criteria, RACI | WS1 | Week 2 |
| Reconciled inventory, crown jewels, current-state architecture, 6–8 attack scenarios | WS1 with WS2–WS5 | Week 2 |
| Rules of engagement and evidence-handling standard | WS1 | Week 2 |
| Standards crosswalk v1 (existing registers, CIS Benchmark and AWS FSBP rows by ID; published mappings as candidates) | WS1 | Week 2 |
| Methodology, rating model, sampling rule, workbooks | WS1 with WS2–WS5 | Week 2 |
| Crown-jewel flash readout to steering | WS1 | Week 4 |
| Tier 1 assessment results and critical findings; crosswalk v2 | WS2–WS5, WS1 | Week 7 |
| Tier 2–3 results, detection validation, all findings fact-checked; crosswalk v3 (full catalogue) | WS2–WS5, WS1 | Week 13 |
| Standards cross-check report: coverage matrix, stricter-than and conflict log, "not assessed" requirements, gaps none of the standards cover | WS1 | Week 14 |
| Target hardening baselines and target-state architecture | WS1 with WS2–WS5 | Week 14 |

| Deliverable | Workstream | Due |
|---|---|---|
| Unified findings and control register; prioritized recommendations and remediation roadmap | WS1 | Week 14 |
| Executive report, risk heat map, residual-risk statement, readiness view per standard | WS1 | Week 16 |
| Handover pack: remediation forum design, register handed to GRC, KPIs, re-assessment cadence | WS1 | Week 16 |

## Scope

All AWS accounts under the Organization are in scope, plus the identity planes and every on-chain application and its off-chain supporting services.

| Layer | In scope |
|---|---|
| Org and landing zone | AWS Organizations, Control Tower, OUs, SCPs/RCPs, management, delegated-admin, log-archive and audit accounts |
| OS | Amazon Linux 2023 on EC2, EKS nodes and container hosts; SSM, CrowdStrike Falcon, patching |
| Containers | EKS (control plane, nodes, add-ons, RBAC, Pod Security, network policy), containers on EC2, ECR and the image supply chain |
| Network | VPC, TGW, Network Firewall, NAT, ALB/NLB, WAF, security groups, VPC endpoints, egress control, DNS and registrar |
| Data | S3, EBS, EFS, Aurora PostgreSQL and MySQL, OpenSearch, Amazon Data Firehose, SNS, SQS, AWS Backup |
| Keys and secrets | AWS KMS, Secrets Manager, ACM for cloud workloads; HashiCorp Vault for on-chain signing keys |

| Layer | In scope |
|---|---|
| Identity | Entra ID (workforce), Azure AD B2C (customers), IAM Identity Center, IAM roles and policies |
| Detection | CloudTrail, Config, GuardDuty, Security Hub CSPM, CloudWatch, Splunk SIEM |
| DevSecOps | CI/CD pipelines, IaC, SAST/SCA/secrets scanning, artifact signing, the deploy path to production and to contracts |
| Blockchain | Ethereum and Base (Solidity); Solana (Rust); Daml on Canton Network, with the validator node operated by Blockdaemon; wallets, signers and signing procedures; Alchemy-managed nodes for Ethereum, Base and Solana (RPC, webhooks); oracles; any cross-chain bridges; upgrade admin keys; dApp front-end integrity |
| Privileged endpoints | Devices used to approve multisig or admin transactions, and engineer workstations with production or deploy access (configuration review, sampled) |

**Out of scope for these 16 weeks:** implementation of recommendations (delivery teams own it; a CISO-chaired remediation forum, designed by WS1, tracks it), other end-user devices, SaaS that does not support in-scope services, physical security, and third-party chains the company does not deploy to. They are tracked as follow-on items.

**Third parties in scope:** the ICT providers behind in-scope services (AWS, Microsoft, Alchemy, Blockdaemon, CrowdStrike, Splunk, the CI/CD platform, oracle and bridge providers, and HashiCorp as the Vault Enterprise licence and support provider). Their configuration and contract controls are reviewed, including the DORA Art. 28 register of information where DORA applies. A full vendor-risk program is out of scope.

**Assumptions to confirm**

- Confirmed: "HashiCorp value" is HashiCorp Vault, Enterprise edition (self-managed), used for on-chain key custody or signing.
- Confirmed: Daml programs are deployed on Canton Network, and Blockdaemon operates the validator node that hosts our Daml parties. Solidity contracts run on Ethereum and Base. Still to confirm: whether any cross-chain bridge is used.

- Confirmed: Alchemy manages the Ethereum, Base and Solana nodes (RPC, webhooks, indexing) and manages no keys.
- Confirmed: CrowdStrike covers EC2 only. EKS pods are in use and Fargate is not, so pod-level runtime coverage (Falcon container sensor or GuardDuty Runtime Monitoring) is a WS2 assessment point.
- Detection, response and resilience are covered inside WS1–WS5 rather than as a separate workstream.
- Confirmed: Entra ID P2 or ID Governance licensing is available for PIM and access reviews.
- Core team of 8 for 16 weeks: program manager, lead architect, GRC lead plus one crosswalk analyst, and one assessor per layer workstream (WS2–WS5). If the team is 7, the analyst role must be kept, and the PM role is combined with GRC lead. Depth is not reduced. The timeline was extended from 12 to 16 weeks instead, and work is sequenced by criticality: Tier 1 first, then Tiers 2–3. Contract reviewers need Solidity, Solana/Anchor and Daml skills; any skill the WS5 assessor lacks is covered by a short specialist engagement, decided at gate 1.

## Standards cross-check

NIST CSF 2.0 is the reporting hub. CIS Controls v8.1 and the CIS Benchmarks are the test layer. Tests run against unified controls, and each unified control links directly to the requirements it covers in every standard. A link counts only if it comes from a published mapping or a reviewed direct mapping; links are never inferred through the hub, because CSF outcomes are too broad to carry 800-53 or ISO conformance on their own.

| Standard | Role | Reused from this project | Gap to close |
|---|---|---|---|
| NIST CSF 2.0 | Reporting hub; organizes workstreams, KPIs and views | Mapped on all 386 blockchain controls | — |

| Standard | Role | Reused from this project | Gap to close |
|---|---|---|---|
| NIST SP 800-53 Rev 5 | Detailed control catalogue for depth and customer assurance | Not mapped | Full catalogue, controls and enhancements. NIST's CSF 2.0-to-800-53 reference supplies candidate links only, and each is reviewed before it counts |
| ISO/IEC 27001:2022 (clauses 4–10, Annex A) | Management-system evidence | Mapped on blockchain controls | Add for AWS, OS, container and identity controls |
| AICPA SOC 2 Trust Services Criteria (2017, points of focus revised 2022) | Attestation readiness only; no opinion given | Not mapped | Map with AICPA's published mappings; never inferred through ISO links |
| CIS Controls v8.1 | Safeguard layer (IG1–IG3) | Mapped on blockchain controls | Add for cloud controls using CIS's published CSF 2.0 mapping |
| CIS Benchmarks (versions pinned in the register) | Configuration test procedures: AWS Foundations, AWS Compute, AWS Database (Aurora, OpenSearch), AWS Storage, Amazon Linux 2023, EKS | The Azure CIS register (339 rows) covers Azure services; only its Entra ID identity and logging rows apply here | Import AWS, Amazon Linux 2023 and EKS rows by ID: the largest new effort |
| BSSC (NOS v2, TIS v1, KMS v1, SCS v1, GSP v2) | Blockchain baseline | 325 controls in the register | Mark which apply by role: issuer, integrator, node operator |

| Standard | Role | Reused from this project | Gap to close |
|---|---|---|---|
| OWASP SCSVS / SC Top 10, SEAL, CCSS v9.0 | Contract, key-custody and Web3 operations supplements | 61 supplementary controls | — |
| PCI DSS 4.0.1 | Only where cardholder data is in scope | Not mapped | Use the PCI-to-CSF 2.0 informative reference as a starting point |
| DORA / MiCA / NYDFS Part 500 | Regulatory overlays | DORA and MiCA mapped on blockchain controls | NYDFS not mapped; legal confirms applicability |

### Cross-check method

1. **Normalize.** One row per requirement, with ID, source, pinned version, requirement level (MUST/SHOULD, CIS Level 1/2) and a short paraphrase. ISO, PCI SSC and AICPA text is licensed, and CIS content has its own terms of use, so the register stores IDs and paraphrases, never copied text.
2. **Link.** Link each unified control to each standard's requirement with a set-theory relationship from NIST IR 8477: equal, subset of, superset of, intersects with, or no relationship. Published mappings come first: NIST's CSF 2.0-to-800-53, CIS Controls v8.1-to-CSF 2.0, ISO 27001:2022-to-CSF 2.0 and PCI DSS 4.0.1-to-CSF 2.0. NIST does not test non-NIST mappings, so a second reviewer checks every judgement-based link and a sample of published ones. Links taken from informative references are labeled candidate in v1, and they support no conformance claim until reviewed.
3. **Score.** A passing test counts as full conformance only where the relationship is equal or superset of. Subset and intersects count as partial, and the report says what is left uncovered.
4. **Merge.** Each unified control gets one test procedure and one evidence item. Overlaps are flagged Duplicate or Related, following the convention already in the registers. From week 3, tool-driven tests run against native benchmark and FSBP IDs. A new crosswalk version changes links only: it never changes test procedures and never reopens fieldwork.

5. **Resolve differences.** Where one standard is simply stricter, the strictest applicable requirement wins; for example, PCI DSS keeps audit logs 12 months, while BSSC NOS asks for 180 days of security logs. Real conflicts go to Legal and are logged with a rationale; for example, record retention under NYDFS 500.6 or MiCA against privacy erasure. A regulatory requirement cannot be risk-accepted.
6. **Log gaps.** Risks in scope that no standard covers well, such as Solana account validation, Daml authorization or RPC-provider trust, get program-specific controls labeled as such.
7. **Report per standard.** Coverage and conformance per standard come from the same results. Requirements that no tested control reaches are reported as "not assessed", never as passed. This is an internal readiness view, not a certification or attestation opinion.

## Governance and roles

WS1 owns governance and the program-wide view. A steering group chaired by the CISO accepts the findings and approves the recommendation roadmap. System owners fact-check findings but cannot withdraw them. Every recommendation ends with a recorded owner decision: accept, defer with a date, or reject with a CISO-approved risk acceptance. A recommendation tied to a regulatory requirement can only be accepted, or deferred with a date and compensating controls.

| Role | Responsibility |
|---|---|
| Executive sponsor (CISO) | Chairs steering; approves scope, rating model, final report and risk acceptances; decides disputed findings |
| Program manager (WS1) | Plan, RAID log, status, steering agenda, gate reviews |
| Lead security architect (WS1) | Reference architecture, methodology, consistency across workstreams, final recommendations |
| GRC lead (WS1) | Crosswalk, unified findings and control register, evidence standard; owns the register after handover |

| Role | Responsibility |
|---|---|
| Workstream leads (WS2–WS5) | Run assessments; own their findings and draft recommendations for their layer |
| System owners (platform, SRE, product, Web3 engineering) | Provide access and evidence, fact-check findings, decide on recommendations, own remediation |
| SOC / incident response | Receive critical findings for immediate containment; deconflict active testing |
| Legal / compliance | Regulatory applicability (PCI, DORA, MiCA, NYDFS), conflicts between standards, rules of engagement |
| Internal audit (optional) | Observes the methodology so its results can be relied on later |

### RACI for a finding

| Activity | WS lead | WS1 architect | GRC | System owner | CISO |
|---|---|---|---|---|---|
| Assess and draft finding | R/A | C | I | C | I |
| Rate risk and map to standards | R | A | R | C | I |
| Fact-check finding | R/A | C | I | C | I |
| Decide a disputed finding | C | R | I | C | A |
| Write recommendation and target baseline | R | A | C | C | I |
| Decide on recommendation | C | C | C (records) | R/A | C (A for rejections) |
| Approve risk acceptance | C | C | C (records) | R | A |

### Cadence

- Weekly: 30-minute steering meeting covering progress, critical findings and decisions.
- Twice weekly: WS1 integration session with all workstream leads to remove duplicate findings, align ratings and follow cross-layer attack paths.
- Week 4: crown-jewel flash readout to steering.

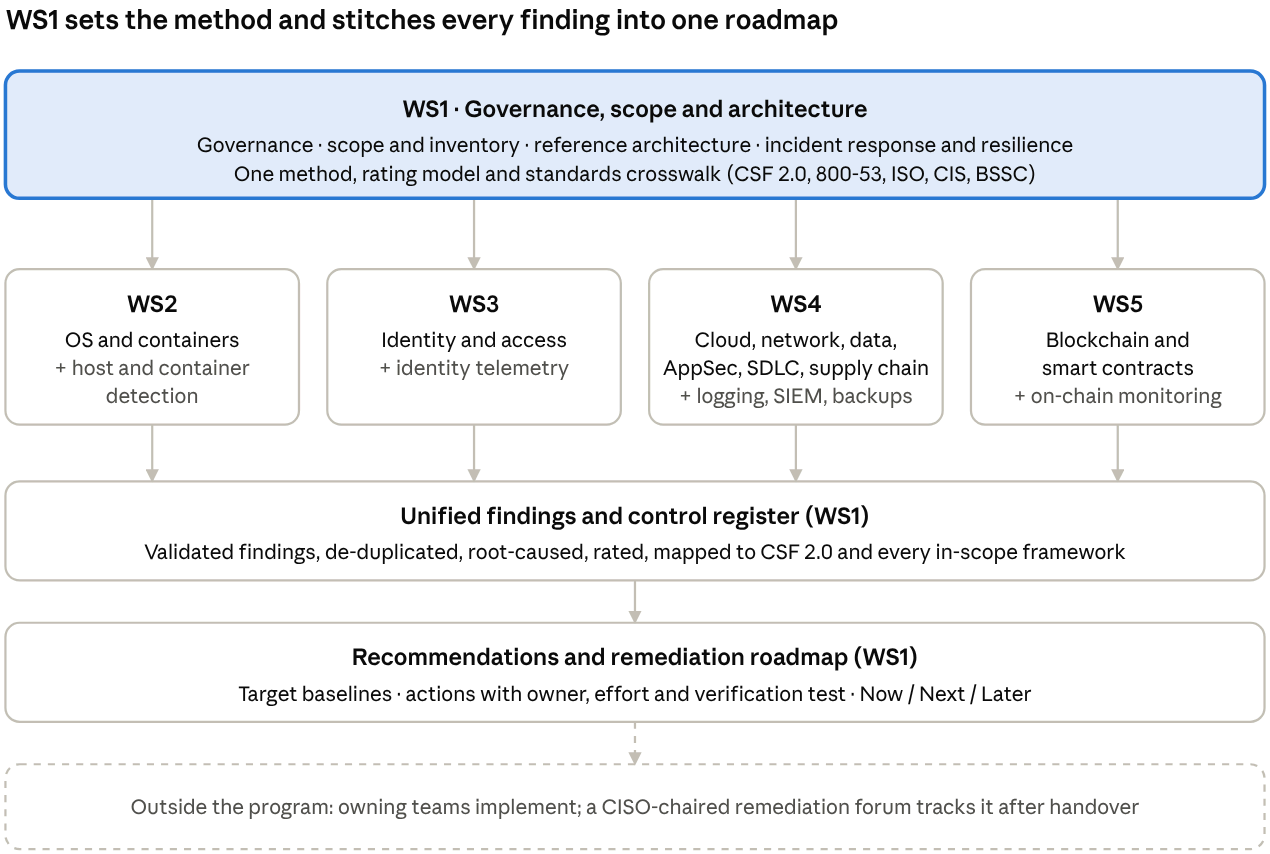
- Gates, each with testable criteria:
  - **Gate 1, week 2:** at least 90% of Tier 1 access granted; inventory reconciled against the Organizations account list; crown jewels and attack scenarios approved; rules of engagement signed; specialist-skill decision recorded.
  - **Gate 2, week 7:** 100% of Tier 1 assessed; every critical finding escalated, with its containment status known; findings issued by week 6 fact-checked; crosswalk v2 done.
  - **Gate 3, week 13:** Tiers 2–3 assessed per the sampling rule; detection validation done; every finding fact-checked; crosswalk v3 done; Tier 1 recommendations reviewed with owners.
  - **Gate 4, week 16:** final report signed; owner decisions recorded; critical containment retested; assessor access removed.
  - A missed gate needs a recorded CISO decision: extend, add staff, or move named scope.
- Critical findings go to the system owner, CISO and SOC within 24 hours. Urgent fixes run through the owner's change process, not through the program.
- Owners have 5 working days to fact-check a finding. Disagreement is recorded next to the finding and goes to the CISO. No response counts as confirmed.

**Evidence handling and rules of engagement**

- Findings and evidence are classified Restricted and kept in one named repository with need-to-know access. Findings on signing keys and treasury contracts are effectively an exploit map.
- Assessors collect configuration and metadata only, never secrets or key material.
- Assessor access is read-only, time-limited, logged, and removed at week 16. GRC retains the evidence under the records policy.
- Passive, read-only collection (Security Hub, Inspector, Entra exports) starts as soon as access is granted. Active testing (DAST, attack-surface scans, fuzzing, detection-validation tests) runs only under signed rules of engagement, approved at gate 1. They cover targets, time windows, stop conditions and SOC deconfliction. No destructive tests run in production, contract fuzzing runs on forks or testnets only, and testing stays within the AWS, Microsoft, Alchemy and Blockdaemon testing policies.

# Workstreams

There are five workstreams. WS1 sets scope, method and architecture, integrates every finding, and owns the cross-layer incident response and resilience review. WS2–WS5 each assess one layer, including that layer's logging and detection, and feed their findings to WS1. Each layer workstream produces three things: an assessment report, a target hardening baseline, and prioritized recommendations in the common format.




Program structure · WS1 over four layer workstreams

## WS1 — Governance, scope and architecture

- **Governance model:** charter, RACI, steering, gate criteria. WS1 also designs the remediation governance that takes over at week 16: a CISO-chaired remediation forum that meets monthly, an exception process (90 days maximum, with compensating controls), KPI reporting and an annual re-assessment.
- **Scope and inventory:** accounts, OUs, VPCs, clusters, data stores, identities, contracts and keys, reconciled against Organizations, Config, EKS and Entra exports, with data classification.

- **Crown jewels:**
  - signing keys and Vault root and unseal material;
  - Canton party keys and contract data on the Blockdaemon-operated validator;
  - admin and upgrade multisigs and treasury contracts;
  - the AWS management account and delegated-admin security accounts;
  - Entra Global Admin and the Entra-to-Identity Center trust;
  - the B2C login-to-withdrawal path;
  - the CI/CD deploy path to production and to contracts;
  - customer PII and KYC stores; the dApp front end, DNS and registrar.
- **Terminology rule (adopted):** a crown jewel is *what an attacker wants*. Use the term for impact: targets, attack scenarios and ratings. Tier 1 is *what we assess first and in full depth*. Use the term for scope: depth, order, sampling and KPIs. Every crown jewel is Tier 1, and Tier 1 also includes any asset two steps or fewer from a crown jewel.
- **Attack scenarios (week 2):** 6–8 named, cross-layer scenarios drawn from crypto-sector threat intelligence, each with an owner across workstreams. Each one is validated end to end with graph tooling (PMapper or Cartography, Access Analyzer). Examples:
  - phished engineer → Entra → Identity Center → EKS pod → Vault token → signing;
  - malicious signing UI → blind multisig approval;
  - CI compromise → contract upgrade;
  - B2C account takeover → withdrawal.
- **Architecture:** current state with trust boundaries and data flows (on-chain and off-chain) in week 2; target state in week 14. Workstream leads draft STRIDE inputs, and WS5 drafts the protocol threat model for each dApp.
- **Standards cross-check:** WS1 owns the crosswalk and the conflict log (see *Standards cross-check*). The GRC analyst also covers third parties and the DORA register of information.
- **Incident response and resilience (cross-layer):** the IR plan and playbook governance; regulatory incident reporting (DORA major-incident reporting, NYDFS 72-hour notice); BCP and DR with RTO/RPO; and the recommended tabletop exercise. The GRC analyst reviews the documents; WS2–WS5 provide each layer's playbook inputs.
- **Methodology:** findings are rated by attack-path proximity to a crown jewel × impact. CVSS v4.0 is used for technical issues, and value at risk is the impact measure for blockchain findings. The methodology also sets the evidence standard and the finding template.

- **Sampling rule:**
  - Tier 1 (every crown jewel, plus any asset two steps or fewer from one, including internet-facing entry points on those paths): tool-based and manual checks on 100%, in weeks 3–7.
  - Tiers 2–3: tool-based checks on 100% from week 3, plus a documented manual sample of at least 25% and at least 3 per class, in weeks 10–12.
- **Integration:** a unified findings and control register. WS1 removes duplicates across workstreams, groups findings by root cause and traces each finding to every in-scope standard.
- **Recommendations roadmap:** Now (0–30 days), Next (30–90 days), Later (90+ days), with dependencies, effort and owner teams. Tier 1 recommendations are drafted on a rolling basis from week 5.
- **Recommendation format:** every recommendation states:
  - the finding and its rating;
  - the unified control ID, with its linked requirements in every in-scope standard;
  - the specific action and target configuration;
  - the owner team, effort (S/M/L) and priority;
  - the verification test.

## WS2 — OS and containers

- **Assesses:**
  - Amazon Linux 2023 AMIs and the fleet against CIS Amazon Linux 2023, using Inspector CIS scans: patch currency, SELinux mode, SSH vs SSM access, IMDS settings, CrowdStrike and SSM coverage.
  - EKS against the CIS EKS Benchmark (kube-bench): RBAC, Pod Security, network policy, add-ons and node IAM.
  - ECR image hygiene and containers on EC2.
  - Vault Enterprise platform hardening: HSM-backed seal and seal wrap, audit devices, HA and DR replication with a tested failover, namespaces, Sentinel policies, control groups for multi-person approval of signing-key operations, and the host OS.
  - Host and container detection: CrowdStrike detections (including whether the Falcon sensor runs on EKS worker nodes), GuardDuty Runtime Monitoring, and EKS audit and control-plane logs reaching Splunk.
- **Recommended baseline:**

  - OS: a golden-AMI pipeline to CIS Level 1 (Level 2 for internet-facing and signer hosts), SELinux enforcing where workloads allow, SSM-only access, and a 14-day patch SLA for critical issues.
  - IMDS: IMDSv2 required everywhere. Hop limit 1 on EKS nodes that use Pod Identity or IRSA; 2 only on documented container hosts that need it.
  - EKS: private endpoint, access entries, Pod Identity, a customer-managed KMS key for envelope encryption, and default-deny network policies.
  - Pod Security: restricted by default; baseline or privileged only for named system namespaces (CNI and, if deployed, the Falcon node sensor) as tracked exceptions.
  - Admission and runtime: Kyverno or Gatekeeper, signed images verified at admission, and GuardDuty Runtime Monitoring.
  - Detection: host and container detections, and the input to the container-escape playbook.
- **Outputs:** an OS and container assessment report; Amazon Linux 2023 and EKS hardening baselines; specifications for Image Builder and policy as code.

### WS3 — Identity and access

- **Assesses:**
  - Entra ID: Conditional Access, MFA methods, PIM, legacy authentication, break-glass accounts.
  - AWS: Identity Center federation and permission sets, IAM users and keys, Access Analyzer findings, cross-account trust.
  - Workload identity: instance profiles, IRSA or Pod Identity, CI credentials.
  - Azure AD B2C: policies, token lifetimes, MFA, abuse protection, logging.
  - Identity telemetry: Entra and B2C sign-in and audit logs and Identity Protection risk signals in Splunk.
- **Recommended baseline:** phishing-resistant MFA and PIM for every privileged role, just-in-time AWS elevation, zero IAM users or static keys, OIDC for CI, quarterly access reviews, identity-threat detections and the credential-compromise playbook, B2C hardening, and an Entra External ID migration plan.
- **Outputs:** an identity assessment report, a privileged-access map and a target identity baseline.

## WS4 — Cloud, network, data, logging, application security, SDLC and supply chain

WS4 is the broadest workstream, so it runs in two tracks. The platform track (cloud, network, data, logging) runs in weeks 3–7, with write-up during the weeks 8–9 buffer; the application track (AppSec, SDLC, supply chain) runs in weeks 5–13.

- **Cloud foundation:** Organizations and Control Tower structure, SCPs, RCPs and declarative policies, root access, Security Hub CSPM (FSBP, CIS AWS Foundations) and Config results.
- **Logging and detection:**
  - The org CloudTrail trail and VPC flow logs.
  - GuardDuty protection plans and Security Hub CSPM findings flowing into Splunk.
  - Log retention set by the strictest applicable standard.
  - The MITRE ATT&CK detection coverage map across all layers, built from WS2, WS3 and WS5 inputs.
  - Detection validation: atomic tests for the top attack scenarios in weeks 10–11, under the rules of engagement, to prove priority detections fire into Splunk.
- **Network:** VPC and TGW segmentation, egress through Network Firewall and NAT, security groups, VPC endpoints, ALB/NLB exposure, WAF rules, DNS and registrar locks, and an external attack-surface scan.
- **Data and resilience:**
  - KMS key policies and rotation.
  - Encryption, access and TLS enforcement for S3, EBS, EFS, Aurora, OpenSearch, Amazon Data Firehose, SNS and SQS.
  - Secrets Manager rotation.
  - Backup Vault Lock, backup copies and a sampled restore test.
- **Application security:**
  - OWASP ASVS 5.0 at full depth for Tier 1 apps: the B2C login-to-withdrawal path, admin consoles, top APIs and the dApp front end (CSP, SRI, build provenance).
  - Tool-based checks for all other apps.
  - DAST on internet-facing endpoints, under the rules of engagement.
- **SDLC and supply chain:** CI/CD controls and branch protection; SAST, SCA, secrets and IaC scanning coverage; SBOM, signing and provenance (SLSA level); CI-to-cloud credentials and deploy rights.

- **Recommended baseline:** a landing-zone guardrail set; a logging standard with priority cloud detections; a segmentation and egress pattern; a data-protection and backup standard; secure SDLC gates; and a path from SLSA Build Level 2 to Level 3.
- **Outputs:** cloud, network and data assessment; the validated detection coverage map; AppSec findings; an SDLC maturity score (OWASP SAMM); a guardrails-as-code specification.

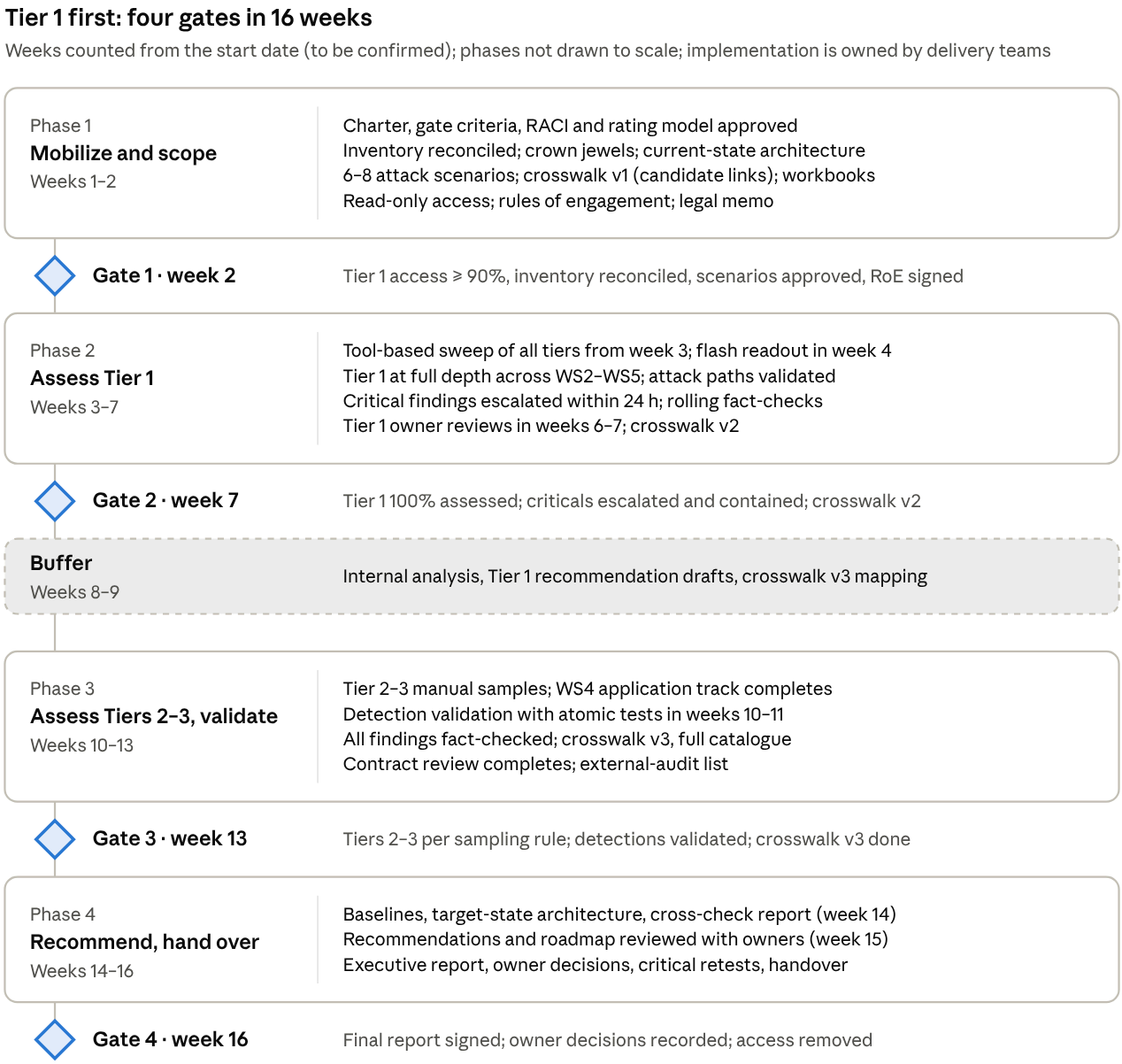
### WS5 — Blockchain and smart contracts

- **Assesses** against BSSC (NOS, TIS, KMS, SCS, GSP), OWASP SCSVS / SC Top 10, SEAL and CCSS:
  - Contract code: Solidity, Solana Rust and Daml, using Slither/Aderyn, Foundry fuzzing on forks and Anchor account checks. Full manual review covers the privileged, upgrade and value-moving paths of all Tier 1 contracts. The rest gets tool-based checks, and contracts that need a line-by-line audit go on the external-audit list.
  - The upgrade and admin-key model, including multisig thresholds, signer independence and timelocks.
  - Signing procedures and signer devices: transaction simulation, no blind signing, transfer limits.
  - Vault key custody and signing, with Vault audit logs reaching Splunk.
  - Alchemy node configuration and API keys for Ethereum, Base and Solana; oracles; any cross-chain bridges.
  - The Blockdaemon-operated Canton Network validator: party hosting and party-key management, our access and API authentication, backups, and Blockdaemon's assurance evidence and contract terms, assessed against BSSC NOS.
  - On-chain monitoring and incident readiness.
- **Recommended baseline:**
  - Contract SDLC gates.
  - A multisig + timelock admin model.
  - A signing-architecture decision: Vault Transit has no secp256k1 key type, so compare an HSM, AWS KMS (ECC_SECG_P256K1 keys), MPC and plugin options for Ethereum. Ed25519 for Solana is native to Transit.
  - Alchemy and Blockdaemon configuration hardening, and on-chain monitoring.
  - Contract-exploit and signing-key-compromise playbooks, with SEAL 911 contacts and pre-signed pause transactions.

- **Outputs:**
  - A blockchain assessment scored against the 386-control register.
  - Contract review findings.
  - Protocol threat models.
  - A key-custody design recommendation.
  - A list of contracts that need an external audit; the external audits themselves are out of scope.

## 16-week roadmap

Tier 1 is assessed first, so the highest-risk findings and their owner reviews land early. Weeks are counted from the program start date, which is still to be confirmed. Weeks 8–9 are a two-week buffer for internal analysis and crosswalk work only. Once the start date is set, place the buffer over the main holiday or leave period that the 16 weeks cover. Critical path: access request (week 0) → inventory and tiering (week 1) → attack scenarios (week 2) → Tier 1 fieldwork (weeks 3–7) → Tier 1 owner reviews (weeks 6–7) → Tier 2–3 fieldwork (weeks 10–12) → recommendations (week 14) → sign-off (week 16).




16-week roadmap · 4 phases, 4 gates, holiday buffer

## KPIs

Program KPIs measure how complete and how usable the assessment is, not how much has been remediated. The posture metrics (Security Hub pass rate, CIS scores, MFA coverage) are recorded as baselines here and handed to the remediation governance as its KPIs.

| KPI | Target |
|---|---|
| Inventory reconciled against Organizations, Config, EKS and Entra exports | ⩾ 98% |
| Crown-jewel attack scenarios analyzed end to end, with a validated path or a recorded break | 100% |
| Tier 1 assets assessed at full depth by week 7 | 100% |
| Tier 2–3 assets: tool-based checks / manual sample per sampling rule | 100% / rule met |
| Requirements in every in-scope standard with a recorded relationship decision ("no relationship" included) by week 13 | 100% |
| Judgement-based links checked by a second reviewer; conflicts with a recorded resolution | 100% / 100% |
| Critical findings escalated within 24 hours; owner's containment retested by the program within 7 days | 100% / 100% |
| Findings overturned at fact-check (quality measure) | ⩽ 10% |
| Priority detections validated as firing into Splunk | ⩾ 80% |
| Critical and high recommendations with a recorded owner decision by week 16; all others by the first remediation forum | 100% |
| Critical and high recommendations accepted into Now or Next | Reported, not targeted |
| Gate criteria met, or a CISO decision recorded | 4 of 4 |

**Posture baselines handed over** (measured in week 7, tracked by remediation governance): Security Hub pass rate, CIS Amazon Linux 2023 / EKS scores, EDR + SSM coverage, privileged MFA/JIT coverage, IAM users and static keys, pipeline-gate coverage, contracts with audit + timelocked admin, and mean time to detect where incident data exists.

# Risks, dependencies and open questions

The biggest risk is late access to environments and evidence. Without read-only access by week 2, fieldwork can't finish by week 7. The second risk is recommendations that owners don't adopt, which the governance model and owner validation are designed to prevent.

| Risk | Impact | Mitigation |
|---|---|---|
| Read-only access (audit role, Splunk, Entra, Vault, repos) granted late | Tier 1 fieldwork slips past week 7 | Access request in week 0 with CISO sponsorship; access is a gate-1 criterion; passive collection starts as soon as access lands |
| Capacity: about 8 people for an estimated 100–150 person-weeks at full depth | Depth slips in WS4 and WS5 | 16 weeks instead of 12; automation-first tooling; WS4 run as two tracks; re-estimate at gate 1 once account, cluster and codebase sizes are known |
| Skills gap on Solana/Anchor or Daml/Canton | Shallow contract review | Specialist engagement for any missing skill, decided at gate 1 |
| Full-catalogue crosswalk effort (800-53 alone has over 1,000 controls and enhancements) | WS1 becomes the bottleneck | Dedicated GRC analyst; published mappings first; v1/v2/v3 staging; buffer weeks used for crosswalk work |
| Mapping errors or inferred links carried into findings | Overstated compliance claims | Direct links only, candidates labeled, NIST IR 8477 relationship types, partial-credit scoring, second-reviewer check |
| Findings or evidence leak | Exploit map for signing keys and contracts | Restricted classification, need-to-know repository, no secrets collected, access removed at week 16 |
| Licensed standard text (ISO, PCI SSC, AICPA, CIS) copied into shared registers | Licensing breach | Store IDs and paraphrases only; licensed copies stay with GRC |

| Risk | Impact | Mitigation |
|---|---|---|
| Owners don't decide on recommendations | Report sits on a shelf | Recorded owner decision per recommendation; CISO approval for rejections; regulatory items cannot be rejected |
| A critical issue is found mid-assessment | Exposure while the report is in progress | 24-hour escalation to owner, CISO and SOC; containment retested by the program |
| Regulatory scope unclear (PCI, DORA, MiCA, NYDFS) | Wrong framework depth | Legal applicability memo by week 2 |
| Public holidays and leave periods (they depend on the start date) | Fieldwork and owner reviews slip | Place the two-week buffer over the main holiday period once the start date is set; schedule Tier 1 owner reviews before it |

### Open questions for you

- [ ] Named leads for the five workstreams, and which contract skills (Solidity, Solana/Anchor, Daml) the WS5 assessor has.
- [ ] Program start date. None is assumed; all weeks are counted from it.
- [ ] Number of AWS accounts, regions and EKS clusters; number and size of contract codebases. These drive the gate-1 re-estimate.
- [ ] Is cardholder data processed anywhere? Which licenses (MiCA CASP, NYDFS BitLicense or charter) apply?
- [ ] Is ISO 27001 certification or a SOC 2 report a target? That decides who reviews ISO clauses 4–10 and how deep.
- [ ] Should SP 800-190 (containers), SP 800-218 SSDF and SP 800-63B (authentication) be mapped, or only used as sources for test procedures?
- [ ] Is AI/LLM use (Amazon Bedrock, coding assistants in the SDLC) in scope?
- [ ] Is any cross-chain bridge in use? Are all Daml party keys held on the Blockdaemon-operated validator, or do we hold any ourselves?
- [ ] Where Vault Enterprise runs (accounts, hosts, cluster and replication topology); who holds contract admin and upgrade keys today.
- [ ] Existing CI/CD platform (GitHub Actions, GitLab, other) and IaC tool.

## Next steps

Once this charter is approved, we build the program step by step:

1. **Step 2 — WS1 governance pack:** governance model, rating model, finding and recommendation templates, gate criteria, and the access request list.
2. **Step 3 — Standards crosswalk v1:** the 386 blockchain controls and the Entra ID rows of the Azure register, plus new AWS, Amazon Linux 2023, EKS and identity rows. Published mappings are loaded as candidate links, and the conflict log is started.
3. **Step 4 — Scope and reference architecture:** inventory template, crown-jewel list, trust boundaries and threat-model outlines.
4. **Step 5 — Assessment workbooks:** one per workstream (WS2–WS5), generated from the crosswalk, with test procedures, evidence prompts and scoring.
5. **Step 6 — Report and roadmap templates:** executive report with per-standard views, heat map, and the Now / Next / Later remediation roadmap with handover pack.

## Sources


- NIST CSF 2.0 informative references: lists the published mappings to SP 800-53 Rev 5, CIS Controls v8.1, ISO/IEC 27001:2022 and PCI DSS 4.0.1.
- Azure AD B2C FAQ: no longer sold to new customers since May 1, 2025; supported until at least May 2030.
- Vault Transit secrets engine: lists the supported key types; secp256k1 is not among them.
- Project registers: Unified Blockchain Control Register (386 controls) and Azure CIS Control Register (339 rows).